# Sri Lanka Institute of Information Technology

## B.Sc. Honours Degree in Information Technology

Specialized in Cyber Security

Final Examination
Year 3, Semester 1&2 (2024)

## IE3032 – Network Security

Duration: 2 Hours

June 2024

Instructions to Candidates:

- This paper has 4 Questions.
- 10 Minutes reading time is allocated for this paper
- Answer all questions in the booklet given.
- The total mark for the paper is 100.
- This paper contains 7 pages, including the cover page.
- One A4 paper can be brought into the exam hall

## Question 01 Network Attacks and Security [25 marks]

a. Analyze and describe the relationship between a Threat Actor, Asset, Vulnerability, Attack, and Impact.

**(5 marks)**

b. For each scenario identify the below components of the attacks

- Threat actor and whether internal or external
- Asset being targeted
- Vulnerability being exploited
- Best approach to mitigate that attack.

i. The network administrator uses his unlimited access to the system to make copies of the passwords of regular users.

ii. A different company utilizes a botnet to overwhelm the web server running the online stores. The web server is running on a server that is 7 years old.

**(8 marks)**

c. The company had the following requirements to be implemented in the switch to ensure its security. Write the appropriate commands that must be used.

i. Enable port security on interface Fast Ethernet ports 0/1 and 0/2
ii. Set the maximum allowed MAC addresses to 3 on the interface.
iii. Configure the violation action to be "restricted" on the interface.
iv. Disable all the remaining unused ports. (Interface Range Fa0/3 - 24, G0/1 – 2)

**(6 marks)**

d. Now the company has a large number of devices that obtain IP addresses from the DHCP The company had the following requirements to be implemented in the switch to ensure secure DHCP services. Write the appropriate commands that have to be used.

i. Enable DHCP snooping globally.
ii. Configure the trusted VLANs where the DHCP server is located. (VLAN 1)
iii. Enable DHCP snooping on interface Fa0/23 and Fa0/24
iv. Rate limit on the Fa0/1 interface for 15

**(6 marks)**

## Question 02 ACL and Firewalls [25 marks]

a. A company is planning to deploy a new web application that will be accessible from the Internet. The web application will allow customers to place orders, view product details, and submit support tickets. Due to the importance of the webserver, the company is eager to ensure its security. Additionally, the company's internal network contains servers that handle inventory management, shipping, and other backend operations. The company is also concerned with securing the internal network and wants to have more control over traffic between different parts of the network.

i. Analysed and described the strengths of a zone based firewall, a next-generation firewall, and a web application firewall in the context of this company.

ii. As a network administrator, analyze the situation and recommend the most suitable type of firewall based on the given requirements with the justification for that selection

**(12 marks)**

b. You are instructed to configure a Zone-based policy firewall on Router 3. Write the appropriate commands that have to be used.

i. Create a zone named INTERNAL
ii. Create a zone named EXTERNAL
iii. Assign interfaces Fa0/1 to the INTERNAL security zone and S0/0/1 to the EXTERNAL security zone.

**(6 marks)**

c. The senior network administrator has asked you to create a standard named ACL to prevent access to a file server. The file server contains the database for the web applications. Only the Web Manager workstation PC1 and the Web Server need to access the File Server. All other traffic to the File Server should be denied. You are required to fulfill the below requirements on **R1** and **R2**. Please mention the appropriate commands that have to be used.

i. Configure a named ACL on R1 called "Rule1"
ii. Permit the hosts 192.168.20.1 and 192.168.100.1 for all communication
iii. Deny all other traffic.
iv. Apply the ACL outbound on the Fast Ethernet 0/1 interface.
v. Create an numbered ACL using the number **1** on **R1** with a statement that denies access to the 192.168.20.0/24 network from any other network

**(7 marks)**

## Question 03 VPN and AAA [25 marks]

a. You are the network administrator for a large company that handles medical data. Your company has recently expanded and now has remote employees working from different locations around the world. In addition, the company's branches need to access the company's network to collaborate on projects and share information.

i. Explain the functionality and differences between a site-to-site VPN and a remote access VPN.

**(2 marks)**

ii. Identify and justify the best approach for defending the communications of this company with its branches and the remote employees

**(4 marks)**

b. A medium-sized company has multiple offices across the country, and each office has its own network devices, such as switches, routers, and firewalls. The company wants to implement a centralized authentication and authorization system for all network devices to enhance security and simplify management. The company has two main requirements: first, network administrators should be able to manage all network devices from a central location using a single set of credentials; second, the company wants to keep track of who is accessing the network and what actions they are taking, so it can monitor and audit network activity. As the network administrator, you have decided to implement TACACS+ and RADIUS as the authentication and authorization protocols for the network devices.

| Device | Interface | IP Address | Subnet Mask | Default Gateway | Switch Port |
|---|---|---|---|---|---|
| R1 | G0/1 | 192.168.1.1 | 255.255.255.0 | N/A | S1 F0/1 |
| | S0/0/0 (DCE) | 10.1.1.2 | 255.255.255.252 | N/A | N/A |
| R2 | G0/0 | 192.168.2.1 | 255.255.255.0 | N/A | S2 F0/2 |
| | S0/0/0 | 10.1.1.1 | 255.255.255.252 | N/A | N/A |
| | S0/0/1 (DCE) | 10.2.2.1 | 255.255.255.252 | N/A | N/A |
| R3 | G0/1 | 192.168.3.1 | 255.255.255.0 | N/A | S3 F0/5 |
| | S0/0/1 | 10.2.2.2 | 255.255.255.252 | N/A | N/A |
| TACACS+ Server | NIC | 192.168.2.2 | 255.255.255.0 | 192.168.2.1 | S2 F0/6 |
| RADIUS Server | NIC | 192.168.3.2 | 255.255.255.0 | 192.168.3.1 | S3 F0/1 |
| PC-A | NIC | 192.168.1.3 | 255.255.255.0 | 192.168.1.1 | S1 F0/2 |

| | | | | | |
|---|---|---|---|---|---|
| PC-B | NIC | 192.168.2.3 | 255.255.255.0 | 192.168.2.1 | S2 F0/1 |
| PC-C | NIC | 192.168.3.3 | 255.255.255.0 | 192.168.3.1 | S3 F0/18 |

Refer to the above table and you are required to fulfill the below requirements. Write the appropriate commands that have to be used.

i. For backup purposes, configure a local username of "Admin" and a secret password of "pwd1234' on R2.
ii. Configure the AAA TACACS server IP address and secret key (tcspwd) on R2.
iii. Configure AAA login authentication for console access on R2.
iv. Configure the AAA RADIUS server IP address and secret key (rdspwd) on R3.
v. Configure the line console to use the defined AAA authentication method.

**(9 marks)**

c. The upper management of this company has asked you to select two options: implementing server-based AAA authentication or local AAA authentication. Analyze the situation and recommend the most suitable AAA authentication method between server-based AAA and local AAA authentication. Outline the benefits and drawbacks of each method, and explain how your recommendation will improve network security.

**(5 marks)**

d. A large e-commerce company recently experienced a security breach, which resulted in the theft of customer data such as names, email addresses, and credit card information. The company's security team suspects that the attackers used an eavesdropping attack to gain access to the company's communications.

i. What is an eavesdropping attack and how does it work?
ii. As the network administrator, what steps would you take these attacks from occurring in the future?

**(5 marks)**

## Question 04 Network Defense [25 marks]

a. Imagine you have been hired as a senior security engineer at a company that has been struggling with its information security posture. Due to new regulatory requirements, the senior management has decided that an overall audit and revision of its cybersecurity capability and requirements is needed. Below are the details of the findings after 3 successful attacks on the company's network. Analyze the below scenarios identify the attack that has taken place and identify and justify what is the best form of mitigation that can be used to stop such attacks in the future.

i. After employees complained of connectivity issues further investigation showed that the DHCP server had run out of IP addresses even though the total number of addresses in the pool was much larger than the number of machines connecting to the network

ii. After a few days an employee complained that his account seemed to have been logged in by an unknown person. on further investigation, it was found that the attacker had tried multiple different passwords till the correct one was found.

iii. After complaints about the website being unresponsive it was found that the server was using many resources to keep open a large number of TCP connections that never completed the handshake.

**(9 marks)**

b. The company has now decided to improve its security posture by implementing an overarching security policy and developing DR and BCP plans. Based on the current threats faced by companies, identify two key policy documents that should be developed and what areas each should cover. For each document identify and write two key rules you will include.

**(8 marks)**

c. The company is also redoing its entire network infrastructure and expects to increase its overall network security posture as part of the upgrade. Currently, the HQ is using a simple gateway router with a built-in firewall as its only network defense mechanism. In the future, it is expected that the company email and web server which is currently outsourced will be brought in-house and made accessible to external connections. The email server will be available to all external connections while the web server will be made available to selected external connections based on company policies. Additionally, the internal network of the company is also growing, and it is expected that multiple VLANS will be used in the future to separate the different users into different subnetworks. It is also expected that these networks will have different security needs and there will be a method to provide additional security and filtering for data traveling between the different subnetworks.

i. Use a diagram to illustrate the network topology you believe is optimal for enhancing security at the HQ.

**(3 marks)**

ii. Select and justify the type of firewall you recommend for this scenario.

**(5 marks)**

******